

Please scan the QR code to check in this session

2026

Whats new in Conditional Access



Tim Wolf

Senior Solution Architect, ex-MSFT, Drone Pilot

The 3-Headed Dragon of Conditional Access Policies

We have 3 things that comprise conditional access policies.

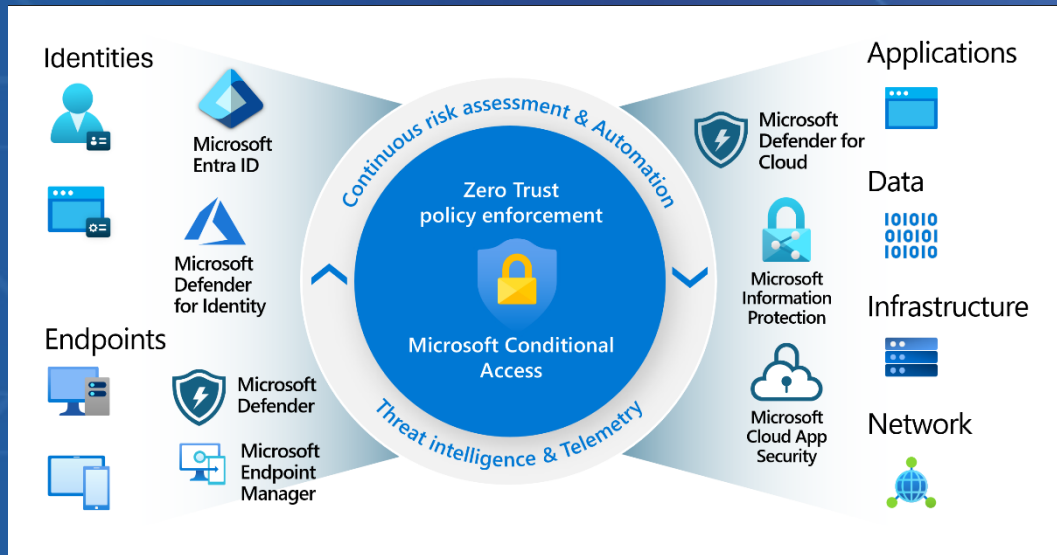
It's always good to do a little bit of review.



Signal

We can group signals into a few categories.

- Users and Groups
- Devices
- Networks
- Apps
- Defender for Cloud Apps
- Risk Detection

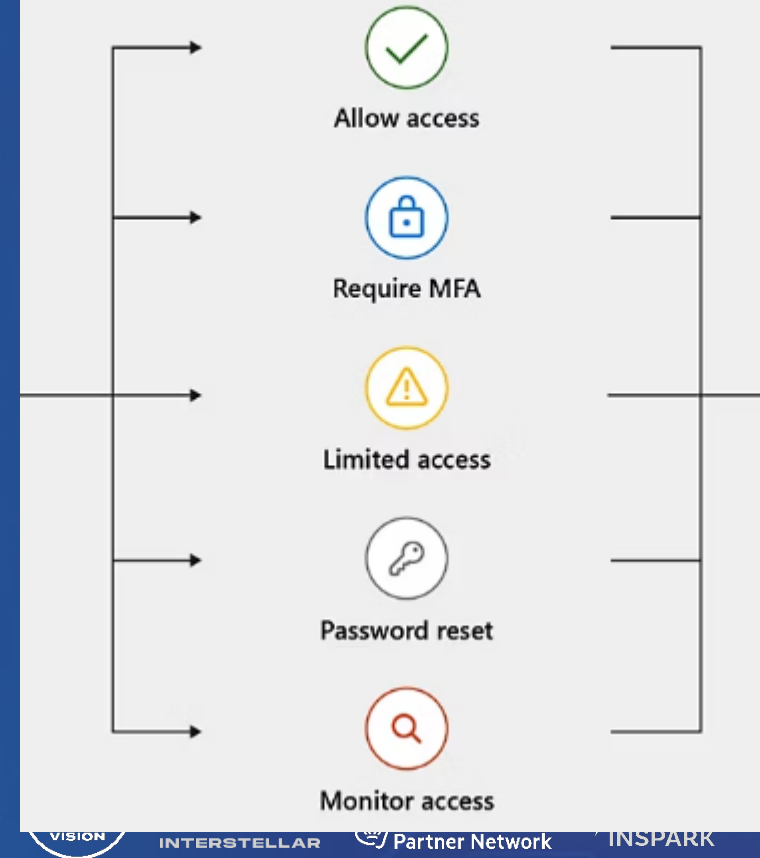


Decisions either block access or grant access.

Grant Access have a few fun options:

- Requiring MFA or Auth Strength
- Requiring Compliant Devices
- Requiring Hybrid-Join (Boo!!!!)
- Require App Protection Policy
- Require Password Change
- Custom Controls
- Terms of Use

Verify every access attempt



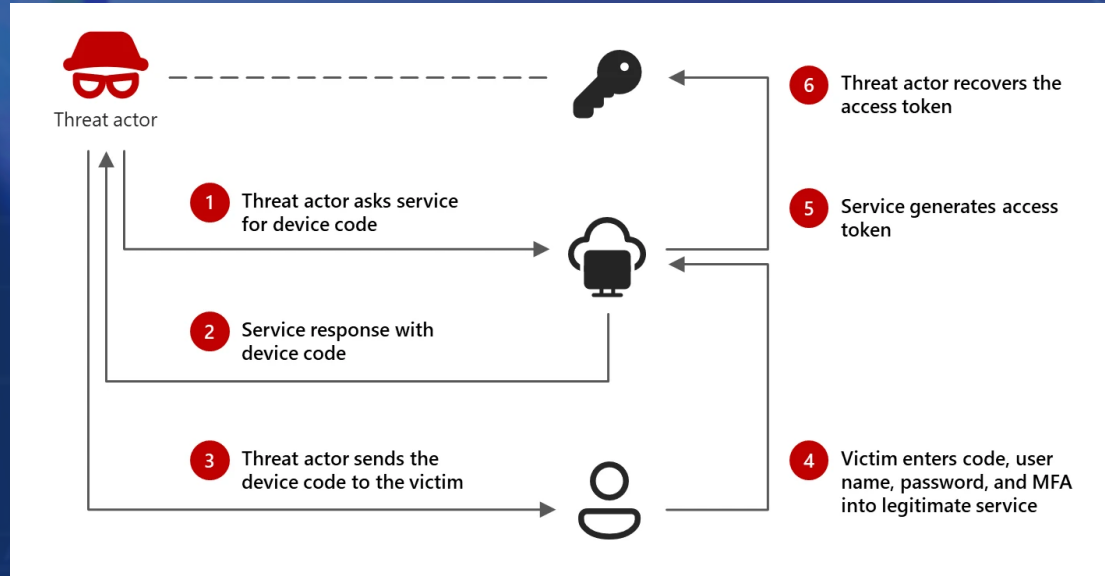
- App-Enforced Restrictions (Conditional Access App Control)
- Enforce Sign-In Frequency
- Controlling Persistence
- Disabling Resilience
- Token Protection
- Enforcing Global Secure Access Profiles



Common Attacks



- MFA Fatigue Attacks
- Downgrade Attacks on User Agents (and Windows Hello)
- Session Hijacking
- MITM
- Device Code Flow Phishing as seen in Storm-2372
- Brute Forcing Basic Authentication
- Token Theft and Replay



User Agent Downgrade Attacks

WHO PROTECTS...

Identity?



WHO PROTECTS...

Devices?



WHO PROTECTS...

Apps?



WHO PROTECTS...

Network?



WHO PROTECTS...

Data?



WHO PROTECTS...

AI?



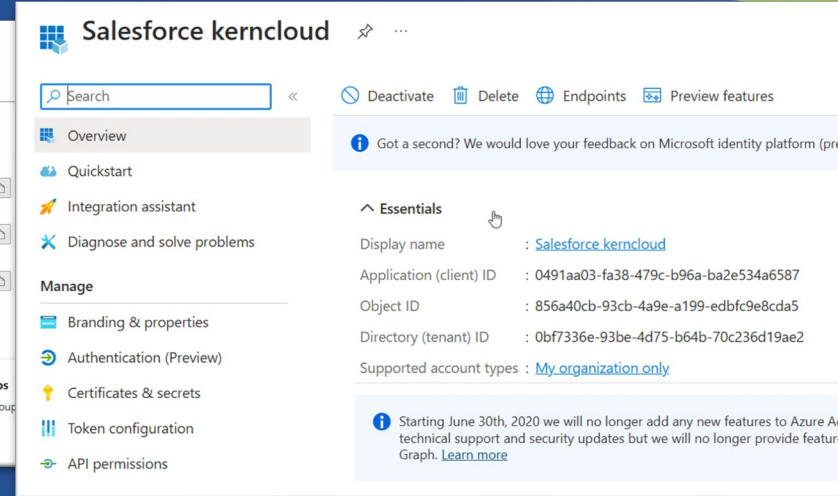
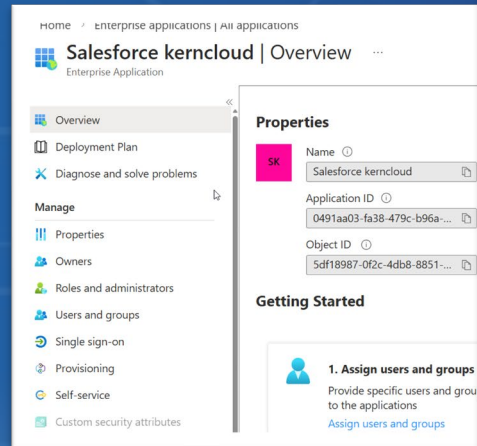


Include Workloads



Workload Protection

Enterprise Apps
App Registration



NO MFA, but Network

Corp Network



NO MFA, but Network

Corp Network



701 - ALL - Workload protection - Specific App: Block Access from untrusted Location

Conditional Access policy

 Delete  View policy information

decisions, and enforce organizational policies.

[Learn more](#)

Name

701 - ALL - Workload protection - Specific A...

Assignments

Users, agents or workload identities 

[Specific service principals included](#)

Target resources 

[All resources \(formerly 'All cloud apps'\)](#)

Network **NEW** 

[Any network or location and all trusted locations excluded](#)

Conditions 

[1 condition selected](#)

Access controls

Grant 

[Block access](#)

Session 

[0 controls selected](#)

Select

1 service principal selected



Workload Identities Identity Pr...
ba0dab59-2093-40b9-9bc2-0a1432a46a...



Policy only applies to single tenant
service p

Locations 

[Any network or location and all trusted locations excluded](#)



Block access

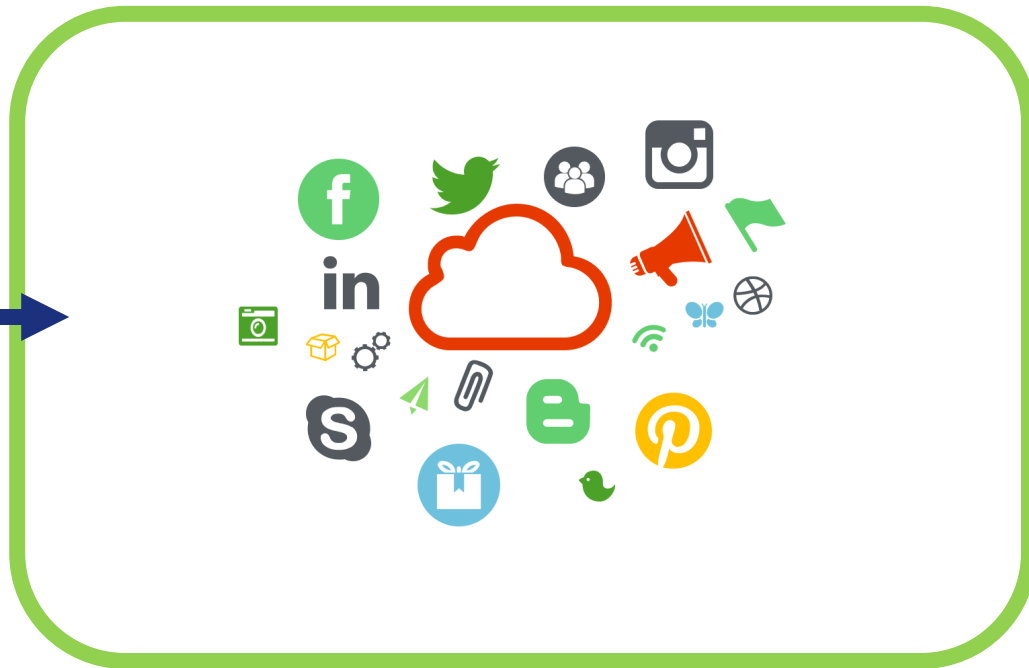


Grant access

Fraud Apps



Fraud Apps



ClientSecret:
"SuperSecretSecret!"

Fraud Apps

700 - ALL - Workload protection - Specific App: Block Access when risk Level is Medium or High

Conditional Access policy

 Delete  View policy information

Control access based on Conditional Access policy to bring signals together, to make decisions, and enforce organizational policies. [Learn more](#)

Name

700 - ALL - Workload protection - Specific A...

Assignments

Users, agents or workload identities

[Specific service principals included](#)

Target resources

[All resources \(formerly 'All cloud apps'\)](#)

Network **NEW**

[Not configured](#)

Conditions

[1 condition selected](#)

Access controls

Grant

[Block access](#)

Control access based on signals from conditions like risk, device platform, location, client apps, or device state. [Learn more](#)

Service principal risk

[2 included](#)

Locations

[Not configured](#)

 Some conditions are not available due to 'Workload identities' selection in policy assignment

Service principal risk

Configure

Yes

No

Configure service principal risk levels needed for policy to be enforced

☒ High

☒ Medium

☐ Low





Include DATA



TOP SECRET.docx  Highly Confidential • Saved ▾

TOP SECRET // ORION DELTA // NOFORN

DOCUMENT ID: X-774-BETA-2026

COPY: 01 OF 05

CLEARANCE REQUIRED: LEVEL 5 (TITAN)

DISTRIBUTION: EYES ONLY – PROJECT LEADERSHIP

Share "TOP SECRET.docx"

 Highly Confidential



evil@hacker.com



Add more

ssor. Initial testing confirms data

t.

orized access, reproduction, or
12-C.

is.

WARNING: > Tracking Beacon Active. This document is digitally watermarked. Physical or digital extraction will trigger an immediate Level 1 Security Lockdown.

PREPARED BY: Directorate of Advanced Research Date: 07-MAR-2026

Data

Home > Conditional Access | Policies

600 - ALL - Insider Risk Policy ...

Conditional Access policy

 Delete  View policy information  View policy impact

Control access based on Conditional Access policy to bring signals together, to make decisions, and enforce organizational policies. [Learn more](#)

Name *

600 - ALL - Insider Risk Policy

Assignments

Users or agents (Preview)

[All users included and specific users excluded](#)

Target resources

[All resources \(formerly 'All cloud apps'\)](#)

Network **NEW**

[Not configured](#)

Conditions

Control access based on signals from conditions like risk, device platform, location, client apps, or device state. [Learn more](#)

User risk

User risk level is the likelihood that the user account is compromised.

[Not configured](#)

Sign-in risk

Sign-in risk level is the likelihood that the sign-in session is compromised.

[Not configured](#)

Insider risk

Insider risk assesses the user's risky data-related activity in Microsoft Purview Insider Risk Management.

[2 included](#)

Insider risk

Control access for users who are assigned specific risk levels from Adaptive Protection, a Microsoft Purview Insider Risk Management feature. Insider risk levels are determined based on a user's risky data related activities. [Learn more](#)

Configure

Yes

No

Select the risk levels that must be assigned to enforce the policy

☒ Elevated

☒ Moderate

☐ Minor

i The insider risk condition requires configuration in Adaptive Protection. [Go to Microsoft Purview](#)





and AI Agents?



Agents

Microsoft Entra Agent ID is a dedicated identity framework introduced at Microsoft Ignite 2025 that treats AI agents as first-class entities — with their own authentication, authorization, lifecycle management, and governance.



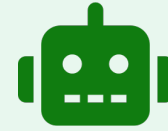
Human Identities

Employees, partners, customers
— managed since Day 1



Workload Identities

Apps, service principals,
managed identities



Agent Identities ✨

AI agents with autonomous
actions at enterprise scale





What Agent ID Enables



Authentication & Authorization

- OAuth 2.0 token-based auth to Microsoft services
- Delegated access — act on behalf of users
- Autonomous access with direct permissions
- Agent-to-agent authentication via MCP/A2A protocols



Agent Registry & Discovery

- Centralized inventory of all agents in your tenant
- Auto-discovery across Copilot Studio, Teams, Foundry
- Metadata: capabilities, tasks, protocols, owner
- Agent blueprints define identity templates



Identity Governance

- Lifecycle management from creation to expiration
- Sponsor & owner assignment (prevents orphaned IDs)
- Entitlement management with time-bound access
- Access reviews for privileged agent identities



Identity Protection

- Risk detection: unusual/unauthorized activities
- Risk signals feed into Conditional Access policies
- Automatic remediation of high-risk compromised agents
- Audit logs in Entra admin center

900 - ALL - Agent

Conditional Access policy

 Delete  View policy

Control access based on Conditional Access policy to bring signals together for access decisions, and enforce organizational policies. [Learn more](#)

Name *

900 - ALL - Agent - Block high

Assignments

Users or agents (Preview) ⓘ

All agents acting as users (Pr

Target resources ⓘ

All resources (formerly 'All clo

Access controls

Grant ⓘ

Block access

900 - ALL - Agent - Block high risk agent identities from accessing resources

900 - ALL - Agent - Block high risk agent identities from a

Conditional Access policy

 Delete  View policy information

Control access based on Conditional Access policy to bring signals together, to make access decisions, and enforce organizational policies. [Learn more](#)

Name *

900 - ALL - Agent - Block high risk agent id...

Assignments

Users or agents (Preview) ⓘ

All agent identities (Preview)

Target resources ⓘ

All agent resources (Preview)

Conditions ⓘ

1 condition selected

Grant

Control access enforcement to block or grant access. [Learn more](#)

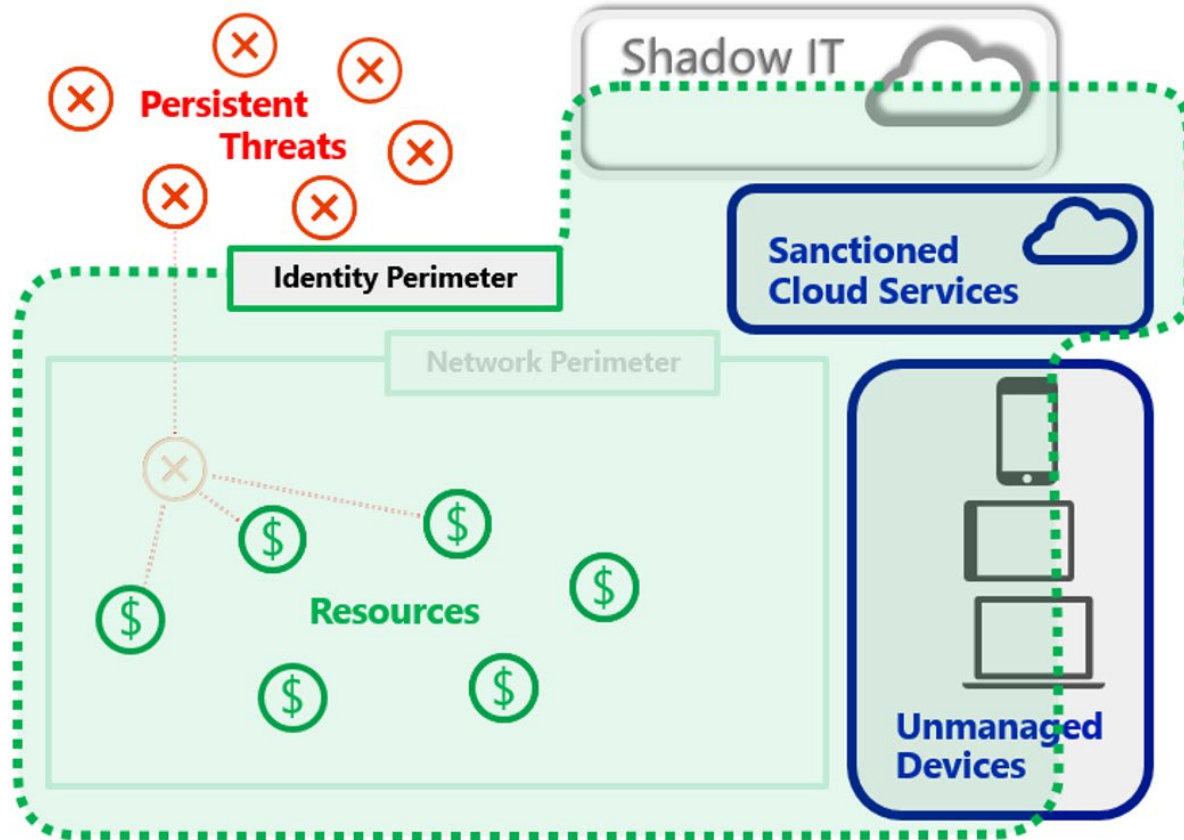
☒ Block access



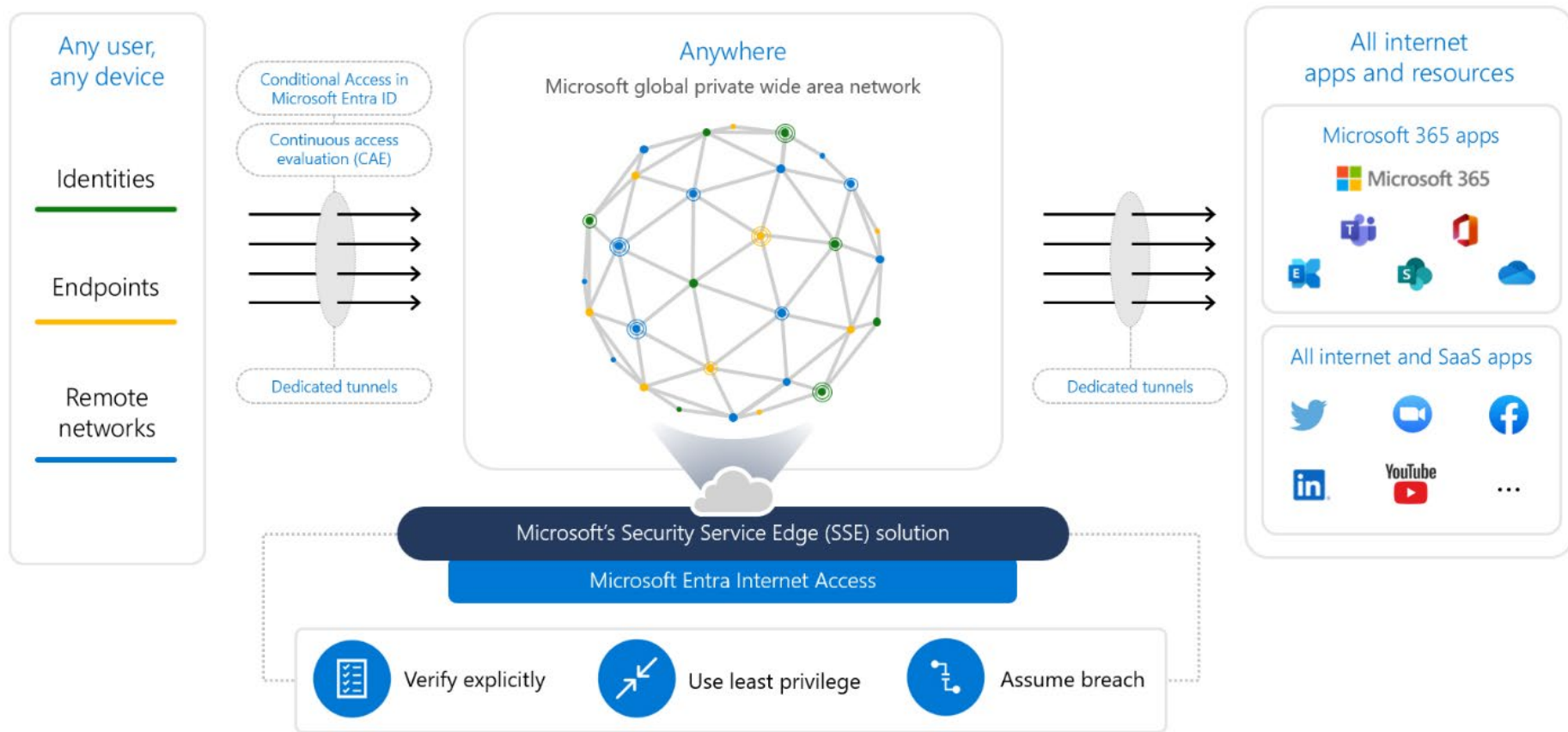
and Network



New Perimeter but not forgotten



New Perimeter but not forgotten



3 U

1.

2.

3.

802 - ALL - Global Secure Access - Specific Websites Block

Conditional Access policy

Delete View policy information View policy impact

Control access based on Conditional Access policy to bring signals together, to make decisions, and enforce organizational policies. [Learn more](#)

Name *

802 - ALL - Global Secure Access - Specific ...

Assignments

Users or agents (Preview)

Specific users included

Target resources

1 resource included

Network

Not configured

Conditions

1 condition selected

Access controls

Grant

0 controls selected

Session

Conditional Access Network Control selected

Tier0 onprem o

Conditional Access policy

Delete View policy information

801 - ALL - Global Secure Access - M365 Traffic: Require Stron

Conditional Access policy

Delete View policy information View policy impact

Control access based on session controls to enable limited experiences within specific cloud applications. [Learn more](#)

☐ Use app enforced restrictions

This control only works with supported apps. Currently, Office 365, Exchange Online, and SharePoint Online are the only cloud apps that support app enforced restrictions. [Learn more](#)

☐ Use Conditional Access App Control

☐ Sign-in frequency

☐ Persistent browser session

Persistent browser session only works correctly when All cloud apps is selected. Please change your cloud apps selection. [Learn more](#)

☐ Customize continuous access evaluation

☐ Disable resilience defaults

☐ Require token protection for sign-in sessions (Generally available for Windows. Preview for MacOS, iOS)

☒ Use Global Secure Access security profile

block FB

Session

0 controls selected

0 controls selected

Global Secure Access (GSA) as a resource, make sure GSA is deployed in your tenant. [Learn more](#)





Bonus points



Universal Token Protection

- Access Token 1H Lifetime
- Evil stuff can happen in 1H
- Not Token will be rejected
 - Service deny it!

The screenshot displays the Microsoft Entra admin center interface for creating a new Conditional Access policy. The policy is named 'Token Protection' and is assigned to 'Specific users included' and '1 resource included'. The 'Network' section is marked as 'NEW' and 'Not configured'. The 'Conditions' section shows '0 conditions selected'. The 'Access controls' section shows '0 controls selected'. The 'Session' section shows '0 controls selected'. The 'Enable policy' section is set to 'Report-only'. The 'Session' pane on the right lists several controls, with 'Require token protection for sign-in sessions' selected and highlighted by a red box. This control is described as 'Generally available for Windows. Preview for MacOS, iOS'. A note below it states: 'The control "Require token protection for sign-in sessions" only works with supported devices and applications. Unsupported devices and client applications will be blocked. Learn more'. Other controls listed include 'Use app enforced restrictions', 'Use Conditional Access App Control', 'Sign-in frequency', 'Persistent browser session', 'Customize continuous access evaluation', and 'Disable resilience defaults'. At the bottom, there is a 'Select' button.

Session - Microsoft Entra admin center

https://entra.microsoft.com/#view/Microsoft_AAD_ConditionalAccess/PolicyBlade

Microsoft Entra admin center

Home > Audit Logs > Conditional Access | Policies >

New

Conditional Access policy

Control access based on Conditional Access policy to bring signals together, to make decisions, and enforce organizational policies. [Learn more](#)

Name *

Token Protection ✓

Assignments

Users or workload identities

Specific users included

Target resources

1 resource included

Network **NEW**

Not configured

Conditions

0 conditions selected

Access controls

Grant

0 controls selected

Session

0 controls selected

Enable policy

Report-only On Off

Create

Session

Control access based on session controls to enable limited experiences within specific cloud applications. [Learn more](#)

☐ Use app enforced restrictions

☐ Use Conditional Access App Control

☐ Sign-in frequency

☐ Persistent browser session

☐ Customize continuous access evaluation

☐ Disable resilience defaults

☒ **Require token protection for sign-in sessions** (Generally available for Windows. Preview for MacOS, iOS)

i The control "Require token protection for sign-in sessions" only works with supported devices and applications. Unsupported devices and client applications will be blocked. [Learn more](#)

☐ Use Global Secure Access security profile

i This option only works with Global Secure Access resources.

Select

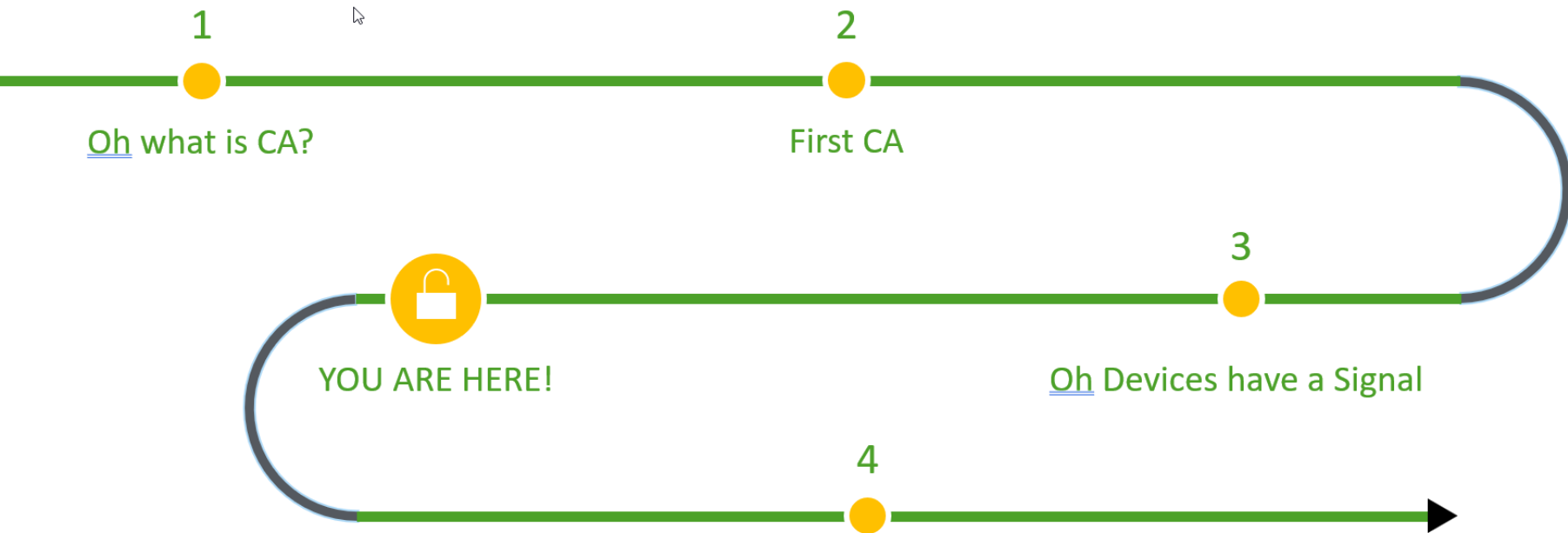
Times

- School
- Office Workers
- Shift-based Env
- After Hour hardening

```
{
  "times": {
    "includeAllTimes": true | false,

    "includeDays": {
      "daysOfWeek": [
        "monday",
        "tuesday",
        "wednesday",
        "thursday",
        "friday",
        "saturday",
        "sunday"
      ],
      "timeZone": "UTC | <IANA/Windows timezone>",
      "startTime": "HH:mm:ss",
      "endTime": "HH:mm:ss",
      "allDay": true | false
    } | null,

    "excludeDays": {
      "daysOfWeek": [
        "monday",
        "tuesday",
        "wednesday",
        "thursday",
        "friday",
        "saturday",
        "sunday"
      ],
    },
  },
}
```



Modernize it!





Please evaluate this session in the App.

THANK YOU

Are there any questions?





Workcation unlocked

After Lunch at 15.00

